EU CRA対策戦略

SEMI規格準拠企業向け技術ロードマップ

2026-03-17

AI Research Agent

エグゼクティブサマリー

SEMI E187/E188準拠をベースに、EUサイバーレジリエンス法（CRA）への効率的な対応を目指します。開発チームは以下の重要マイルストーンを認識する必要があります。

- **最優先期限**: **2026年9月**（脆弱性・インシデント報告義務の先行施行）
- **完全施行**: **2027年12月**（セキュアバイデザイン、SBOM、CEマーキング）
- **基本戦略**: SEMI準拠資産の最大活用＋報告プロセスの新規構築
- **コスト影響**: 脆弱性管理プロセスの維持コスト（5年間サポート義務）

Confidence: High 法的施行スケジュールは確定済みです。

1. CRA適用範囲と対象製品

半導体製造装置の制御PC、組み込みOS、ファームウェアは「デジタル要素を含む製品（PDEs）」として**CRA規制の対象**となります。

- **ハードウェア・ソフトウェア**: EU市場に上市される全てのPDEsが対象
- **OSSの扱い**: 商用製品に組み込まれたOSSコンポーネントは製造者責任
- **SaaS**: リモート処理のみならNIS2対象だが、デバイス側コンポーネントがあればCRA対象

開発チームへの影響:
既存の出荷済み製品に対するサポート期間とパッチ提供義務の範囲特定が急務です。

High Article 2 (Scope)

2. 重要製品分類（Class I/II）の判定

多くの半導体製造装置は「デフォルトカテゴリ」ですが、産業用オートメーション制御システム（IACS）等の機能を持つ場合は**Class I/II**に分類される可能性があります。

- **Default Category**: 自己適合宣言（Module A）が可能。第三者認証不要。
- **Class I/II**: 第三者機関による関与が必要になる可能性あり。
- **判断基準**: ネットワーク機能、特権アクセス管理機能の有無。

開発チームへの影響:
Annex IIIリストに基づき、自社製品機能が「重要製品」に該当しないか精査が必要です。

Medium Annex III / Recital 10

3. SEMI E187/E188とのギャップ分析

既存のSEMI規格対応は有用ですが、CRA準拠には**不足領域（Gap）**があります。ここを埋めることが技術対応の焦点です。

領域	SEMI E187/E188	EU CRA (Annex I)	ギャップ
OS強化	対応済 (Hardening)	必須	**小** (再利用可)
SBOM	Software Inventory	機械可読SBOM	**大** (形式変換必須)
脆弱性管理	パッチ適用プロセス	**24時間以内**の報告	**特大** (運用体制)
設計	マルウェアフリー	セキュアバイデフォルト	**中** (証明が必要)

High SEMI E187/E188 vs CRA Annex I Mapping

4. 技術戦略：SBOMの実装

SEMI E188で要求される「Software Inventory」を、CRAが求める機械可読な**SBOM（CycloneDX/SPDX）**へ変換・高度化する必要があります。

- **必須要件**: 脆弱性データベースとの自動照合が可能な形式であること
- **推奨ツール**: Syft, Grype, Dependency-Track等のOSS活用
- **運用**: ビルドパイプラインへのSBOM生成組み込みと、出荷後の構成管理

開発チームへの影響:
手動管理のインベントリから、CI/CD統合型のSBOM自動生成フローへの移行が必要です。

Medium CRA Annex II / E188 Specification

5. 技術戦略：脆弱性報告（Article 14）

2026年9月より、悪用された脆弱性や深刻なインシデントについて、**認知から24時間以内の「早期警告」**が義務化されます。

- **Early Warning**: 24時間以内にENISA/CSIRTへ第一報
- **Full Notification**: 72時間以内に詳細報告
- **Final Report**: 修正完了後または1ヶ月以内

開発チームへの影響:
技術的な検知から法務・広報へのエスカレーションを含む、緊急対応フローの確立と演習が不可欠です。

High Article 14 (Reporting Obligations)

未対応時のリスク（Alert）

CRAに違反した場合、ビジネス存続に関わる重大なペナルティが課されます。

- **制裁金**: 最大 **1,500万ユーロ** または 全世界売上高の **2.5%**（高い方）
- **市場アクセス**: EU市場での**販売停止・回収命令**（リコール）
- **サプライチェーン**: SEMI準拠を求める顧客からの取引停止（適合宣言書が出せないため）

単なる努力目標ではなく、**「EUへの輸出許可証」**と捉える必要があります。

High Article 53 (Penalties)

段階的導入ロードマップ（Action Items）

開発チームが着手すべきアクションと期限です。

1. **Phase 1: 調査・定義 (〜2024 Q4)**
   - 製品分類（Default vs Class I/II）の確定
   - EU代理人（Authorised Representative）の指名準備
2. **Phase 2: 体制構築 (〜2026 Q2)** ● **最優先**
   - **24時間脆弱性報告フロー**の策定とPSIRT体制強化
   - 既存SEMI資産のCRAマッピングドキュメント作成
3. **Phase 3: 技術実装 (〜2027 Q3)**
   - CI/CDパイプラインへのSBOM生成・脆弱性スキャン統合
   - 技術文書（Technical Documentation）の整備と適合宣言（DoC）準備

Medium Implementation Roadmap based on CRA Timeline

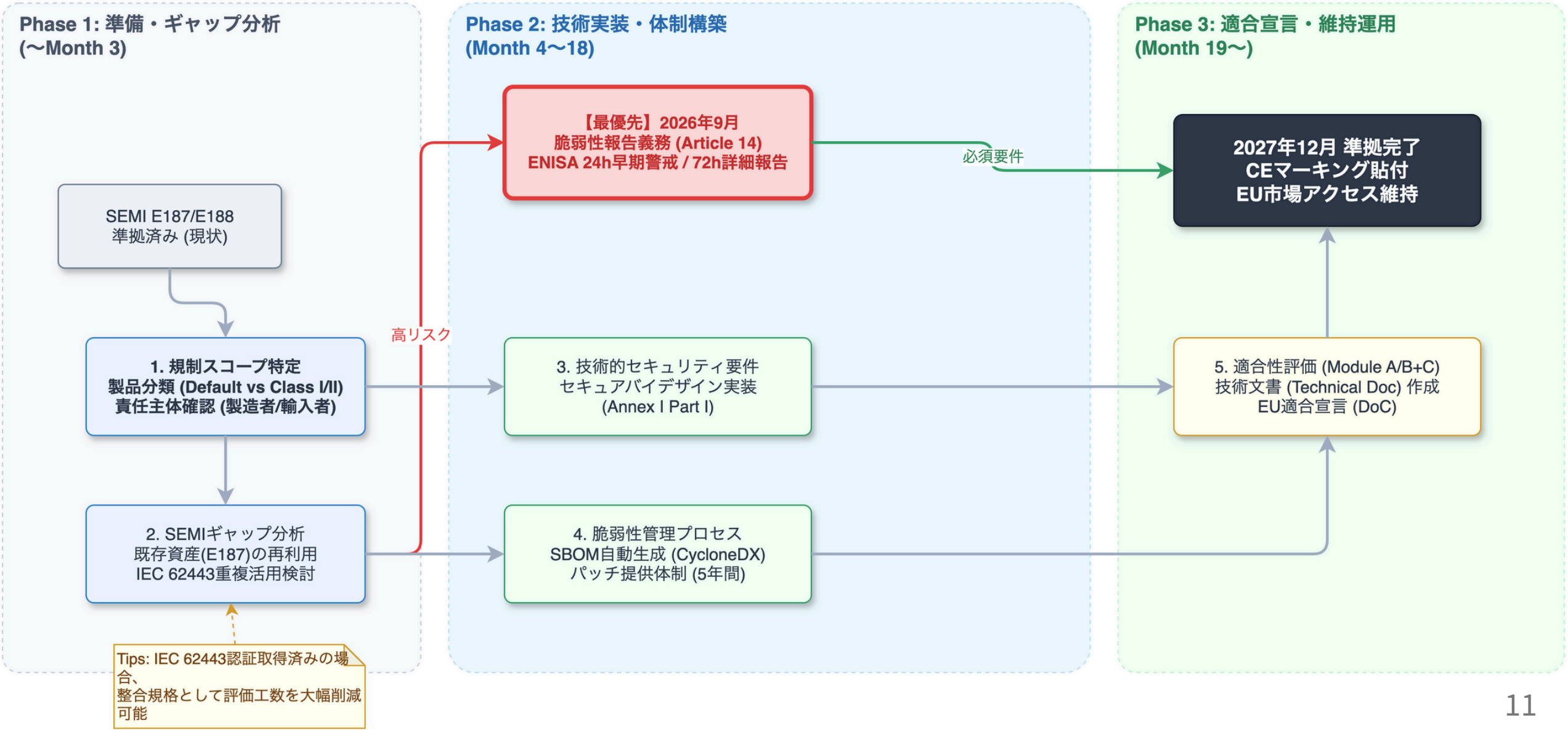
結論：法令対応を競争力へ

CRA対応はコストですが、回避不能な市場参入要件です。

- **SEMI規格の貯金**を活かし、ゼロベースの競合より有利な位置にいます。
- まずは**「2026年9月の報告義務」**をターゲットに、PSIRT体制を整備しましょう。
- 自動化（SBOM/VEX）への投資は、長期的にはソフトウェア品質向上に寄与します。

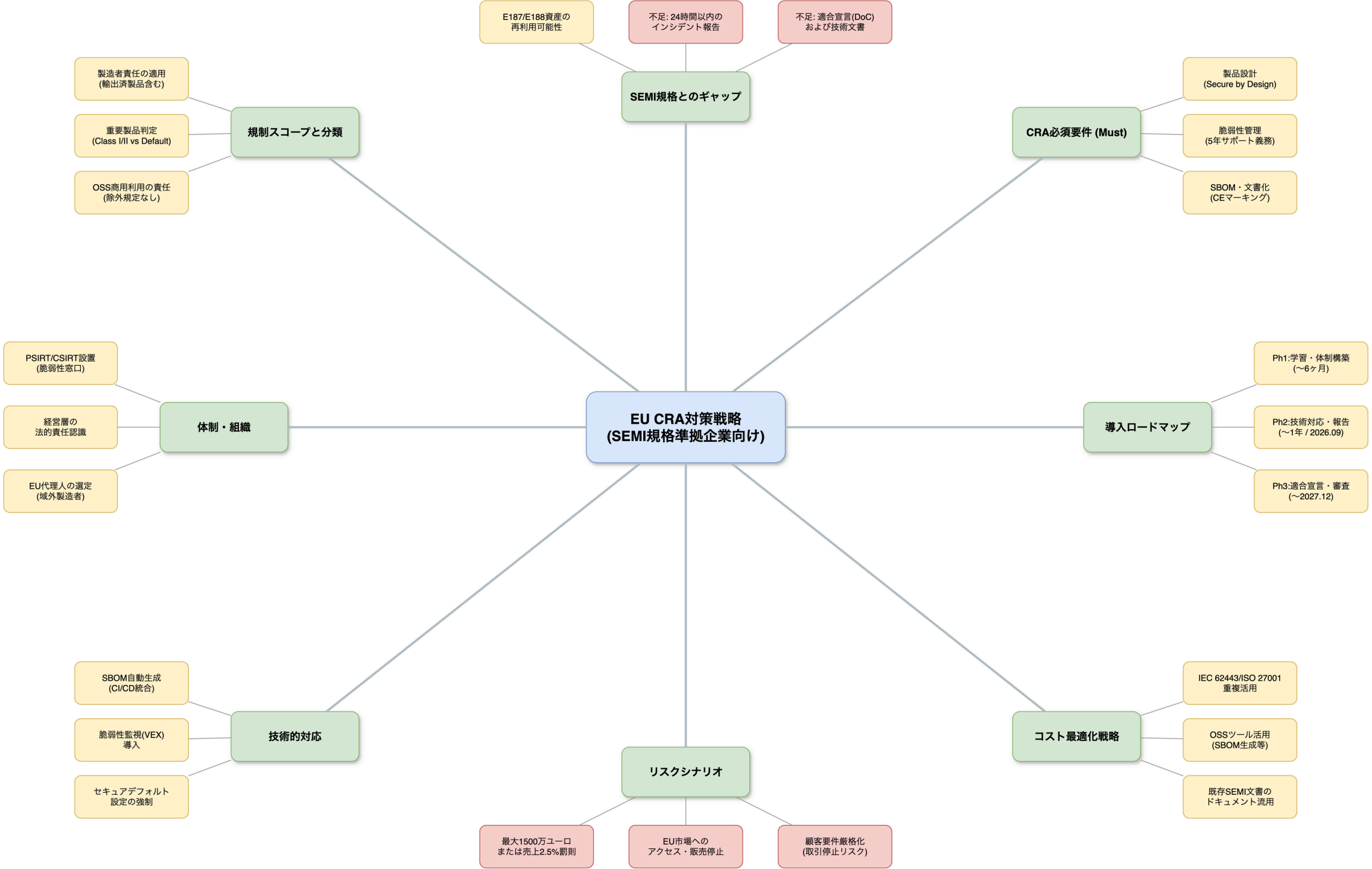
Next Step:
対象製品リストの棚卸しと、SEMI E187/E188対応状況の精査を開始してください。

EU CRA対策ロードマップ：SEMI規格準拠企業向け戦略 (2024-2027)



EU CRA vs SEMI規格(E187/E188) コンプライアンス比較マトリクス

評価軸	SEMI規格 (E187/E188) 現状	EU CRA (必須要件)	判定・必要アクション
規制・法的拘束力	△ 業界標準・契約ベース ・顧客要求による準拠 ・法的罰則は及ばない	EU法による法的義務 ・CEマーキング必須 ・EU域内代理人(AR)の設置	【要対応】体制構築 ・商流整理とEU代理人の契約 ・製品分類(Class I/II)の確定
製品セキュリティ設計	○ 概ね適合 ・マルウェアフリー納品 ・エンドポイント保護 ・不要ポート閉塞	Secure by Default ・デフォルト最高設定 ・完全性検証機能 ・既知脆弱性なしでの出荷	【良好】既存資産活用 ・SEMI E187準拠を基礎に強化 ・完全性検証の実装追加
脆弱性管理・報告	△ ベストエフォート ・保守契約に基づくパッチ提供 ・OSベンダー依存の対応 ・報告義務の規定なし	厳格な監視・報告義務 ・24時間以内の早期警告 ・72時間以内の詳細報告 ・製造後5年間の修正義務	【最重要】運用プロセス刷新 ・PSIRT/監視体制の24/365化 ・ENISAへの報告ルート確立 ・2026年9月先行施行に対応
文書・SBOM	△ ドキュメントベース ・システム構成図(PDF/Excel) ・手動管理の資産リスト	機械可読データ ・SBOM (CycloneDX/SPDX) ・適合宣言書 (DoC) ・技術文書 (Technical File)	【技術的課題】自動化導入 ・ビルドパイプラインへの SBOM生成ツール組み込み ・脆弱性DBとの自動照合
リスク・ペナルティ	○ 商業リスク ・顧客からの信頼低下 ・契約不履行による損害賠償	行政処分・制裁金 ・最大1500万ユーロ または売上高の2.5% ・EU市場からの製品回収・排除	【経営リスク】 ・経営層へのリスク定量的説明 ・コンプライアンス予算確保


EU CRA対策戦略
(SEMI規格準拠企業向け)
SEMI規格とのギャップ
E187/E188資産の
再利用可能性
不足: 24時間以内の
インシデント報告
不足: 適合宣言(DoC)
および技術文書
規制スコープと分類
製造者責任の適用
(輸出済製品含む)
重要製品判定
(Class I/II vs Default)
OSS商用利用の責任
(除外規定なし)
CRA必須要件 (Must)
製品設計
(Secure by Design)
脆弱性管理
(5年サポート義務)
SBOM・文書化
(CEマーキング)
体制・組織
PSIRT/CSIRT設置
(脆弱性窓口)
経営層の
法的責任認識
EU代理人の選定
(域外製造者)
導入ロードマップ
Ph1:学習・体制構築
(〜6ヶ月)
Ph2:技術対応・報告
(〜1年 / 2026.09)
Ph3:適合宣言・審査
(〜2027.12)
技術的対応
SBOM自動生成
(CI/CD統合)
脆弱性監視(VEX)
導入
セキュアデフォルト
設定の強制
コスト最適化戦略
IEC 62443/ISO 27001
重複活用
OSSツール活用
(SBOM生成等)
既存SEMI文書の
ドキュメント流用
リスクシナリオ
最大1500万ユーロ
または売上2.5%罰則
EU市場への
アクセス・販売停止
顧客要件厳格化
(取引停止リスク)

EU CRA 対応ロードマップ (SEMI規格準拠企業向け)

【準備フェーズ】 現状分析・体制構築

2024年12月11日

CRA発効 (Regulation (EU) 2024/2847)
・法的なカウントダウン開始
・移行期間（36ヶ月）のスタート

2025年 上期

【学習・スコープ定義】
・EU輸出製品の棚卸しと責任主体の特定
・重要製品(Class I/II)判定 (Annex III)
・OSSコンポーネントの商用利用状況確認

2025年 下期

【ギャップ分析・体制構築】
・SEMI E187/E188とCRA要件のマッピング
・PSIRT設置、CISO任命、社内教育
・EU代理人 (Authorised Representative) 選定準備

【実装・先行施行フェーズ】 脆弱性報告・技術対応

2026年 上期

【脆弱性管理プロセス実装】
・SBOM自動生成パイプラインの構築
・ENISA/CSIRTへの報告フロー策定
・24時間/72時間報告の模擬訓練

2026年9月11日

★【先行施行】報告義務化 (Art. 14)
・悪用された脆弱性・深刻なインシデントの報告義務
・ENISAおよび各国家機関への24時間以内通知
・違反時の罰則リスク発生開始

2026年 下期

【製品設計・技術文書化】
・Secure by Default / Design 実装完了
・技術文書 (Technical Documentation) の整備
・Annex I 必須要件への適合確認

【完全適用・運用フェーズ】 適合宣言・市場監視

2027年 上期

【適合性評価 (Conformity Assessment)】
・Module A (内部統制に基づく自己宣言) の実施
・重要製品の場合は第三者認証機関 (Notified Body) 審査
・EU適合宣言書 (DoC) のドラフト作成

2027年12月11日

★【完全適用】CRA全面施行
・CEマーキング貼付必須化、市場アクセス要件化
・適合宣言書 (EU DoC) の発行
・市場監視当局による監査・罰則適用の開始

2028年以降

【継続的コンプライアンス】
・製品寿命または5年間のセキュリティサポート義務
・定期的な脆弱性スキャンとアップデート提供
・10年間の技術文書保管

Thank You

AI Research Agent によるリサーチ結果をご覧いただきありがとうございました。

本資料に関するご質問・フィードバックをお待ちしています。